

ANÁLISIS DE INTRUSIONES

CON EL MODELO DIAMANTE

Comprender para **prevenir**. Analizar para **proteger**.



INTEGRANTES:

- 179033 – Alonso Castillo Omar Karim
- 177622 – Cruz Juárez Francisco Javier
- 175031 – Espinoza Aguilar Brian Salvador
- 177685 – Martínez Lara Santiago de la Cruz
- 173030 – Sánchez Ramírez Mayeli
- 177263 – Sánchez Zavala Alan Gilberto



MAESTRO:

SERVANDO LOPEZ CONTRERAS



MATERIA:

CNO V Seguridad Informática



“ En ciberseguridad, el conocimiento es la llave que convierte la información en **defensa**. ”

Contenido

INTRODUCCIÓN	2
COMPRENSIÓN DEL MODELO	2
ANÁLISIS DE EVENTO.....	3
RELACIÓN CON LA KILL CHAIN	4
HILOS DE ACTIVIDAD	4
Hilo 1	5
Hilo 2	5
Relación entre ambos	5
CONCLUSIÓN	5

INTRODUCCIÓN

En la actualidad, las organizaciones se enfrentan constantemente a amenazas cibernéticas que pueden comprometer la seguridad de sus sistemas y de la información. Por ello, es importante contar con metodologías que permitan identificar y analizar los ataques de manera estructurada.

En esta actividad se aplica el Modelo Diamante de Análisis de Intrusiones, el cual permite relacionar elementos clave como el adversario, la víctima, la infraestructura y las capacidades utilizadas durante un incidente. Además, se complementa con la Cyber Kill Chain para comprender las diferentes etapas del ataque y detectar posibles patrones de comportamiento del atacante.

El propósito de este análisis es fortalecer la comprensión de los eventos de ciberseguridad y desarrollar una visión más clara sobre cómo se llevan a cabo las intrusiones dentro de una red informática.

COMPRENSIÓN DEL MODELO

	Descripción	Ejemplo práctico
Adversario	Es el actor o entidad responsable de utilizar una capacidad contra una víctima.	Un grupo de ciberdelincuentes motivado por el beneficio económico que planea una campaña de ransomware contra hospitales.
Capacidad	Se refiere a las herramientas, técnicas y tácticas que el adversario utiliza para llevar a cabo el ataque.	El uso de un malware de tipo troyano diseñado específicamente para evadir la detección de antivirus comerciales y cifrar archivos de manera ultra rápida.
Infraestructura	Es el medio físico o lógico que el adversario utiliza para establecer contacto con la víctima o para entregar sus capacidades.	Un servidor de Comando y Control alquilado en la nube que el atacante usa para enviar órdenes al malware instalado en la computadora de la víctima.
Victima	Es el objetivo del ataque. Puede ser una persona física, una organización, un sistema específico o incluso un sector económico completo.	El departamento de finanzas de una empresa multinacional que recibe correos electrónicos de phishing diseñados para robar credenciales de acceso a las cuentas bancarias corporativas.

ANÁLISIS DE EVENTO

Escenario: una organización detecta comportamiento anómalo en un equipo. El análisis revela:

1. La víctima detecta malware.
2. El malware contiene dominios de Comando y Control (C2).
3. Los dominios resuelven a direcciones IP externas.
4. Logs muestran múltiples hosts conectándose a esas IP.
5. WHOIS/IP revela posible origen del atacante.

Metacaracterística	Descripción del evento
Marca de tiempo	Momento exacto en que los sistemas de monitoreo (SIEM/EDR) disparan la alerta de tráfico inusual hacia el exterior, correlacionado con los registros históricos de los logs de los hosts internos involucrados.
Fase	Comando y Control. El evento se sitúa en la etapa de post-explotación, donde el malware ya residente busca establecer un canal de comunicación persistente con la infraestructura del atacante para recibir instrucciones.
Resultado	Compromiso activo de red. El ataque ha sido exitoso en su comunicación, la presencia de múltiples hosts internos contactando las mismas IP's externas confirma que la amenaza ha logrado propagarse o que el canal de control está plenamente operativo.
Dirección	Saliente. Se observa un flujo de datos que se origina dentro del perímetro de la organización y se dirige hacia activos externos remotos, evadiendo potencialmente filtros de seguridad perimetral básicos.
Metodología	El malware emplea nombres de dominio específicos contenidos en su código para resolver IP's externas, una técnica diseñada para mantener la conexión incluso si el atacante cambia sus servidores físicos.
Recursos	Código malicioso detectados, dominios de C2 identificados en el análisis forense, direcciones IP's externas vinculadas a los dominios y herramientas de inteligencia de amenazas como lo es WHOIS para rastrear al adversario.

1. ¿Quién es el adversario en este escenario?

El análisis de WHOIS/IP revela el posible origen del atacante. Se define como el actor externo responsable de controlar el malware y los dominios de Comando y Control (C2) para comprometer la organización.

2. ¿Cuál es la capacidad utilizada?

La capacidad principal es un malware que ha sido instalado en el equipo de la víctima. Este software malicioso cuenta con la función específica de contener y

ACTIVIDAD 18. ANÁLISIS DE INTRUSIONES CON EL MODELO DIAMANTE

ejecutar consultas a dominios de Comando y Control (C2) para recibir instrucciones externas.

3. ¿Qué tipo de infraestructura se emplea?

- Nombres de dominio específicos.
- Direcciones IP externas.
- Servidores remotos que actúan como puntos de Comando y Control.

4. ¿Quién es la víctima primaria?

La víctima primaria es el host inicial donde la organización detectó por primera vez el comportamiento anómalo y la presencia del malware. Aunque, la víctima se puede considerar que también es la organización ya que la red ha sido penetrada.

5. ¿Existe evidencia de movimiento lateral?

Los logs muestran múltiples hosts conectándose a esas mismas direcciones IP externas. Esto nos muestra que el compromiso se ha extendido desde el equipo inicial hacia otros dispositivos dentro de la misma red interna.

RELACIÓN CON LA KILL CHAIN

Evento	Fase Kill Chain
Detección de malware	Instalación. El malware ya se encuentra dentro del sistema comprometido y ha sido identificado por las herramientas de seguridad.
Envío de phishing	Entrega (Delivery). El atacante utiliza correos electrónicos maliciosos para distribuir el malware hacia la víctima.
Conexión a C2	Comando y Control (C2). El malware establece comunicación con servidores externos para recibir instrucciones del atacante.
Ejecución del malware	Explotación / Ejecución. El código malicioso se ejecuta dentro del host comprometido aprovechando vulnerabilidades o interacción del usuario.

HILOS DE ACTIVIDAD

Del escenario tipo APT:

- Phishing dirigido a administrador.
- Ejecución de malware.
- Conexión a C2.
- Uso del host comprometido como proxy.

- Ataque a segunda víctima.

Hilo 1

1. El administrador recibe un correo de phishing.
2. El usuario abre el archivo o enlace malicioso.
3. El malware se ejecuta en el equipo.
4. El host comprometido establece conexión con el servidor C2.
5. El atacante obtiene acceso remoto y control parcial del sistema.

Hilo 2

1. El atacante utiliza el equipo comprometido como proxy.
2. Desde el host inicial se realizan conexiones hacia otros dispositivos internos.
3. Un segundo equipo de la red es comprometido.
4. El segundo host comienza también a comunicarse con el C2.
5. Se amplía el alcance del ataque dentro de la organización.

Relación entre ambos

El atacante utiliza la primera víctima como punto de apoyo para desplazarse lateralmente dentro de la red corporativa. Este proceso, conocido como pivoting, permite extender el ataque hacia otros sistemas internos utilizando conexiones legítimas desde el host comprometido inicialmente.

CONCLUSIÓN

La presente actividad permitió aplicar el Modelo Diamante de Análisis de Intrusiones como una metodología efectiva para identificar y correlacionar los elementos involucrados en un incidente de ciberseguridad. A través del análisis realizado, fue posible reconocer la relación entre el adversario, las capacidades empleadas, la infraestructura utilizada y las víctimas afectadas, proporcionando una visión más clara sobre el comportamiento del ataque.

Asimismo, la integración con la Cyber Kill Chain facilitó la comprensión de las distintas fases del incidente, desde el reconocimiento inicial hasta el establecimiento de comunicación con servidores de Comando y Control (C2), permitiendo identificar evidencias de propagación y movimiento lateral dentro de la red.

En conclusión, el uso de estos modelos fortalece el análisis forense y la respuesta ante incidentes, ya que permite estructurar la información de manera organizada, detectar patrones de amenaza y apoyar la toma de decisiones para mejorar las estrategias de prevención, monitoreo y protección de la infraestructura tecnológica de una organización.